UNIVERSITY OF TRENTO - Italy

eit Digital MASTER SCHOOL

Cyber Security Risk Assessment Spring 2023

Lecture 03: Developing a Risk Management Plan

Prof. Fabio Massacci

Pierluigi Sartori

Terms and Definition

Is

“Cyber Security Risk Assessment” a correct definition for this course?

"Risk Assessment"

"The process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of an information system. Part of risk management, incorporates threat and vulnerability analyses, and considers mitigations provided by security controls planned or in place.

Synonymous with risk analysis."

Source: NIST Glossary terms and definitions last updated: September 20, 2022

"Risk Management"

"The process of managing risks to organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals resulting from the operation of an information system, and includes:

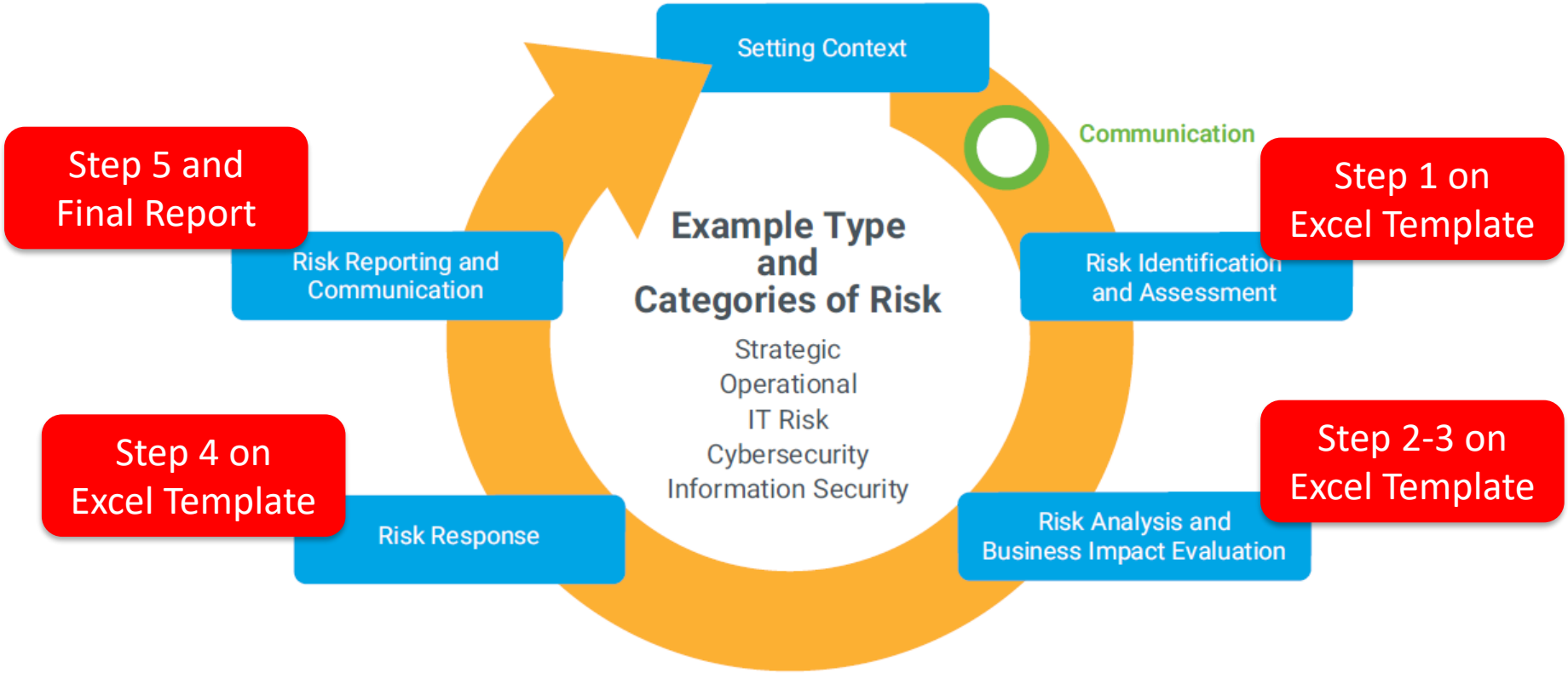
(i) the conduct of a risk assessment;

(ii) the implementation of a risk mitigation strategy; and

(iii) employment of techniques and procedures for the continuous monitoring of the security state of the information system."

Source: NIST Glossary terms and definitions last updated: September 20, 2022

Risk Management Workflow



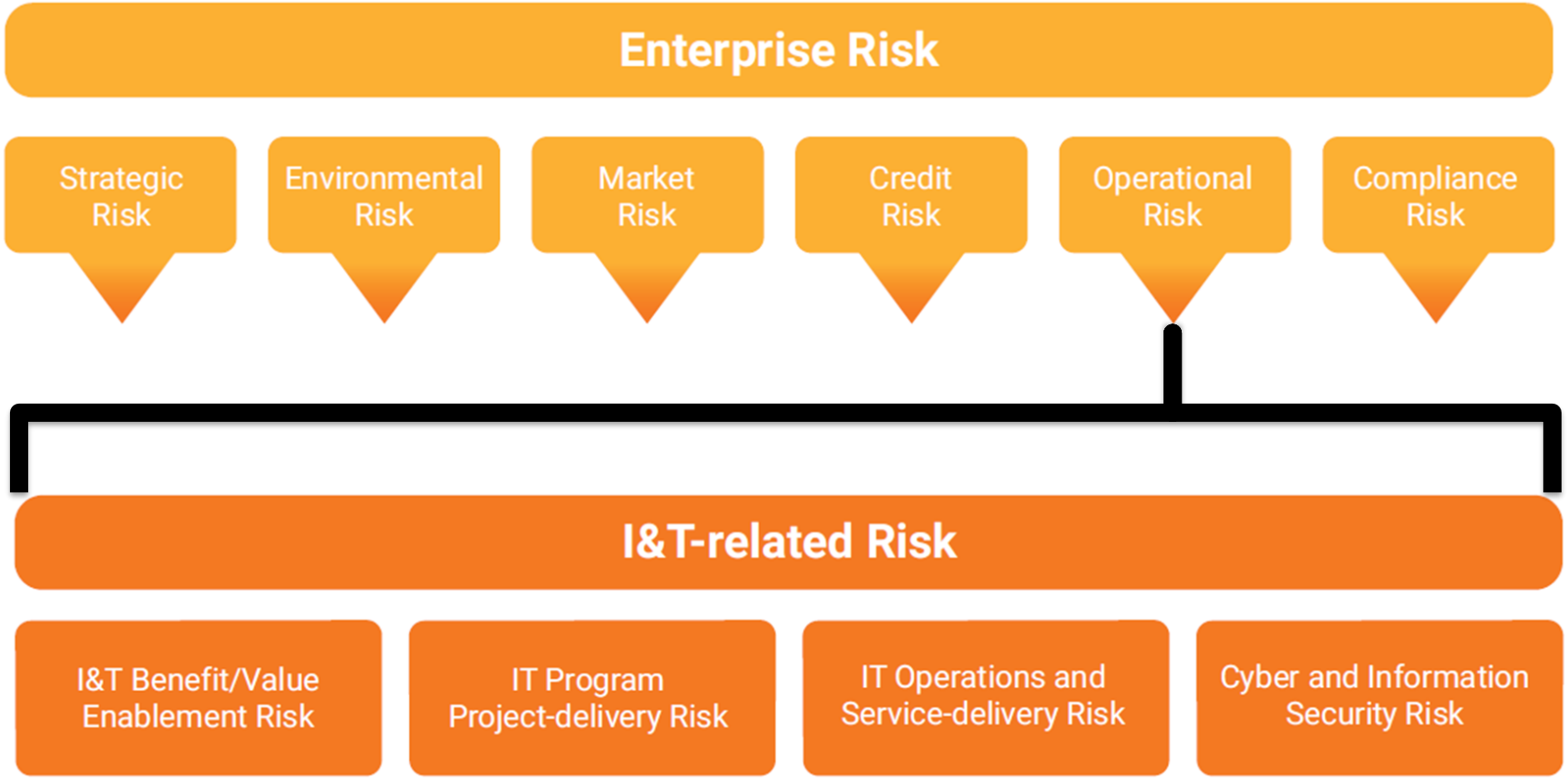
Source: ISACA, *The Risk IT Framework, 2nd Edition*, USA, 2020, figure 5.1,*https://www.isaca.org/bookstore/bookstore-risk-digital/ritf2*

Enterprise (hystorical) Risk Management

Business main risk categories (evolution)

*"**Operational risk** is defined as the risk of loss resulting from inadequate or failed processes, people and systems or from external events. This definition includes legal risk, but excludes strategic and reputational risk."*

Business main risk categories



Just Cyber Risk?

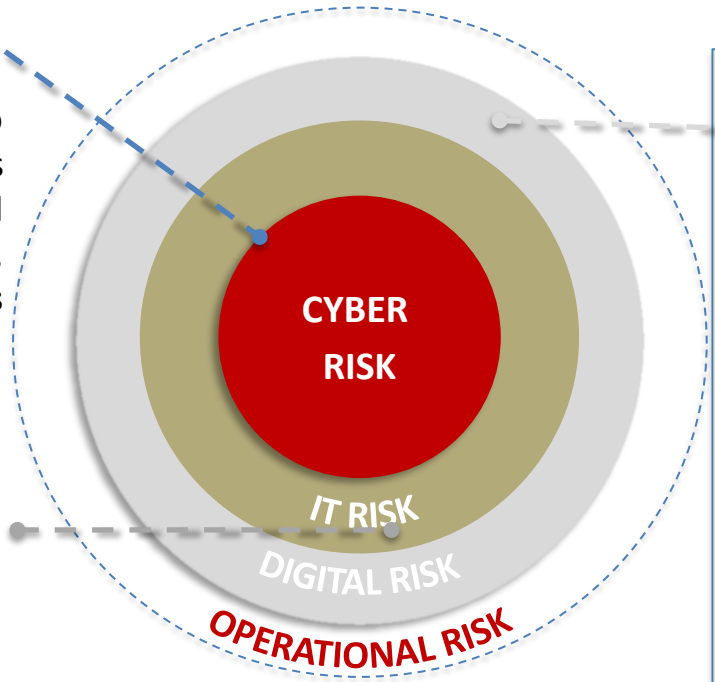
DIGITAL RISKS VS CYBER RISKS

Cyber Risk

The risk of loss or harm related to internetworked information systems deriving from **inadequate** or **failed internal processes**, **personnel**, **technology** or **from external events**

IT Risk

Business risk associated with the **use**, **ownership**, **operation**, **involvement**, **influence** and **adoption** of **IT within an enterprise**



Digital Risk

Risk caused by the adoption and use of a technology and resulting in an **economic loss due to breach of confidentiality**, **failure of integrity** of **systems** and **data**, **inappropriateness or unavailability of systems** and data.

This includes **external events** including **cyberattacks** and **unauthorized access** and risks related to the **intrinsic features** of the technology adopted (e.g., obsolescence, inability to change, etc.)

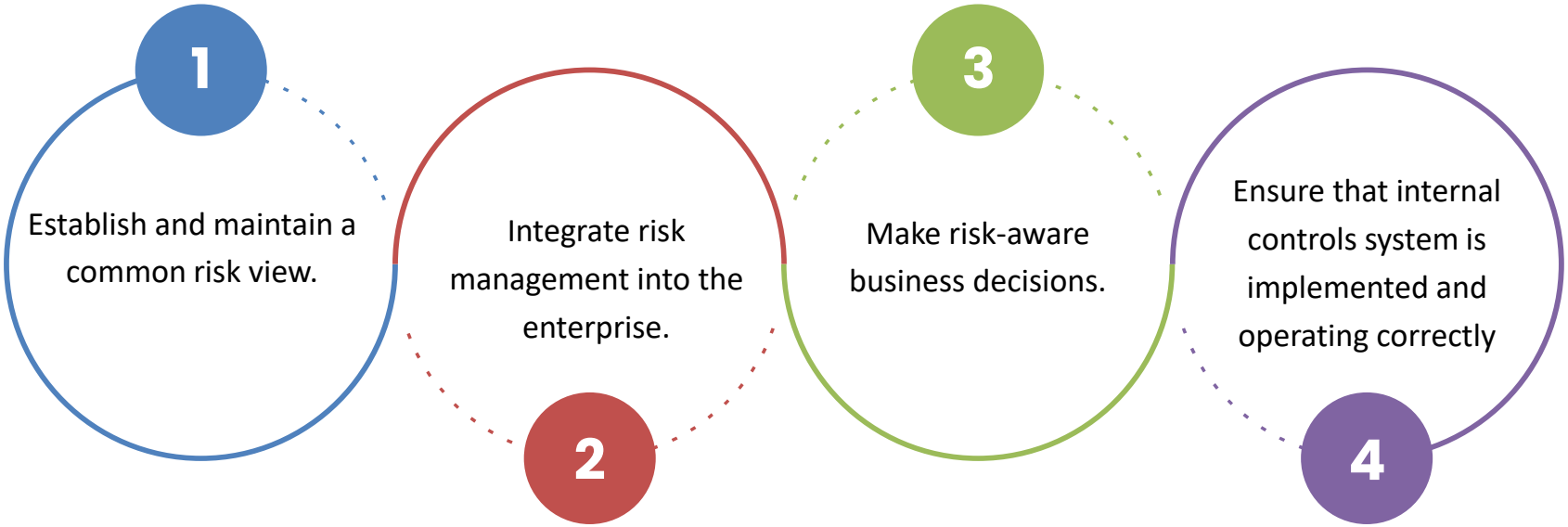
DIGITAL risk management

DIGITAL risk management is the application of risk management methods to information technology in order to manage IT risk, i.e.:

The business risk Risk caused by the adoption and use of a technology and resulting in an economic loss due to breach of confidentiality, failure of integrity of systems and data, inappropriateness or unavailability of systems and data

Risk Management Objectives

The four core objectives of risk management (*or governance*):



Three Lines of Defense

Enhance enterprise risk management capabilities across the organization's various lines of business, establishing a more robust ERM program.

First Line

Owns and manages risk

Establishes control functions

Second Line

Oversees risk

Monitors controls

Third Line

Provides independent testing and assurance

First Line of Defense
Operational Management

IT Department

- Owns and manages risk
- Establishes control functions

Operational managers or business owners are responsible for managing risk (considered risk owners)

Often implemented by the business unit, component or business function that performs daily operation activities

Responsible for implementing corrective actions to address risk that exceeds the defined risk appetite

Expected to:

- Ensure conductive control environment in their business unit
- Implement risk management policies regarding roles and responsibilities
- Execute effective internal control and monitoring in their business units

Second Lind of Defense
Risk and Compliance

Independent Oversight

- Oversees risk
- Monitors controls

Ensures first-line defenses are properly designed, implemented and operating as intended

Risk practitioners work to gain enterprisewide consensus, buy-in and adoption of a risk management standard framework

Establish an accepted risk management standard that defines and enables assessment of the risk management program

Comprised of risk management and compliance functions and expected to:

- Establish business-aligned risk management frameworks.
- Develop, monitor and oversee process and operation of the enterprise's overall risk management program capabilities
- Ensure business functions operate in accordance with the enterprise risk management requirements
- Monitor and report details to the appropriate stakeholders

Third Lind of Defense
Audit

Audit

Provides independent testing and assurance

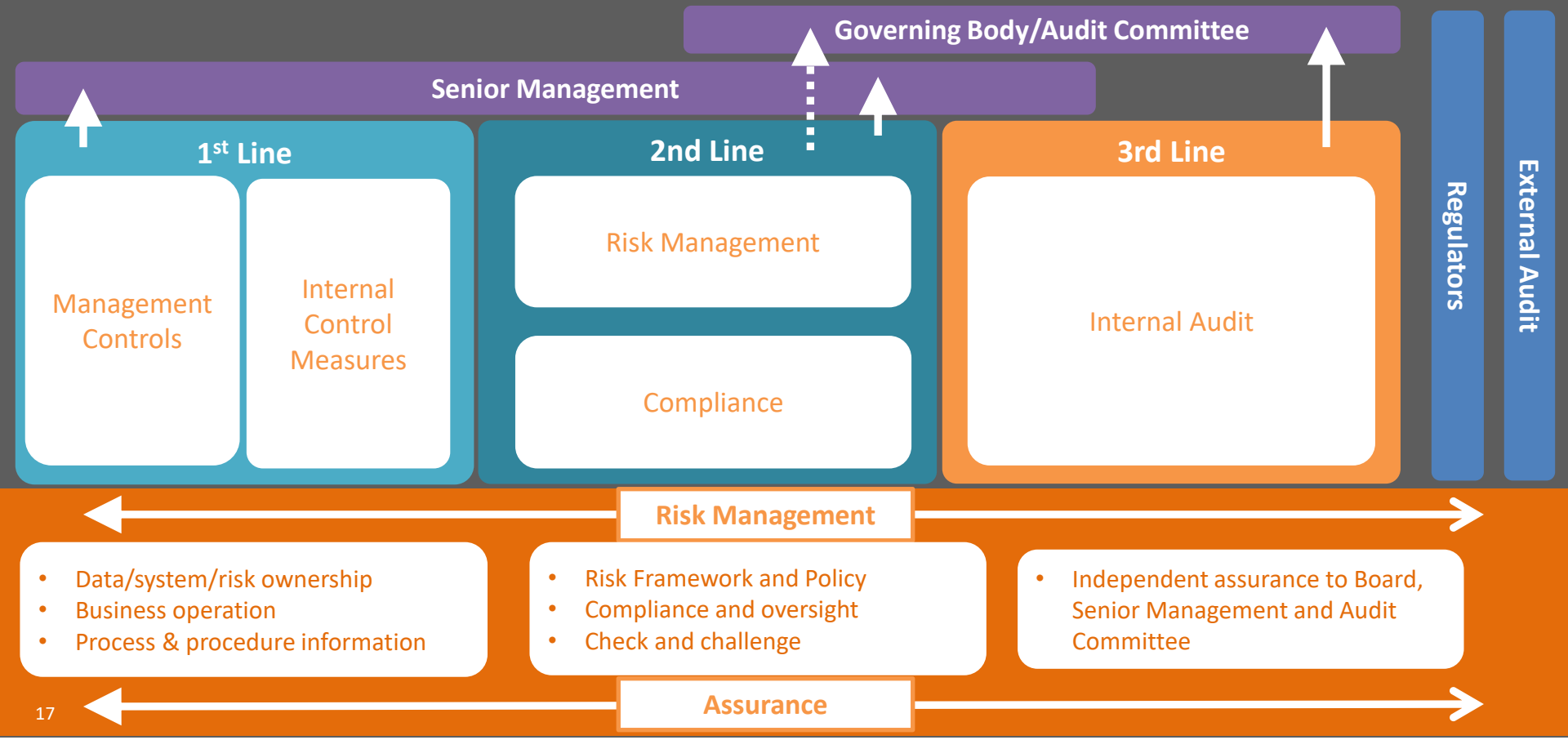
Consists of gaining the appropriate level of assurances through independent and objective reviews performed by internal and/or external audit (if applicable).

The risk practitioner may be called to speak to the design, implementation, effectiveness and efficiency of first- or second-line processes, practices, activities and controls and provide the appropriate context, based on the desired level of assurance required.

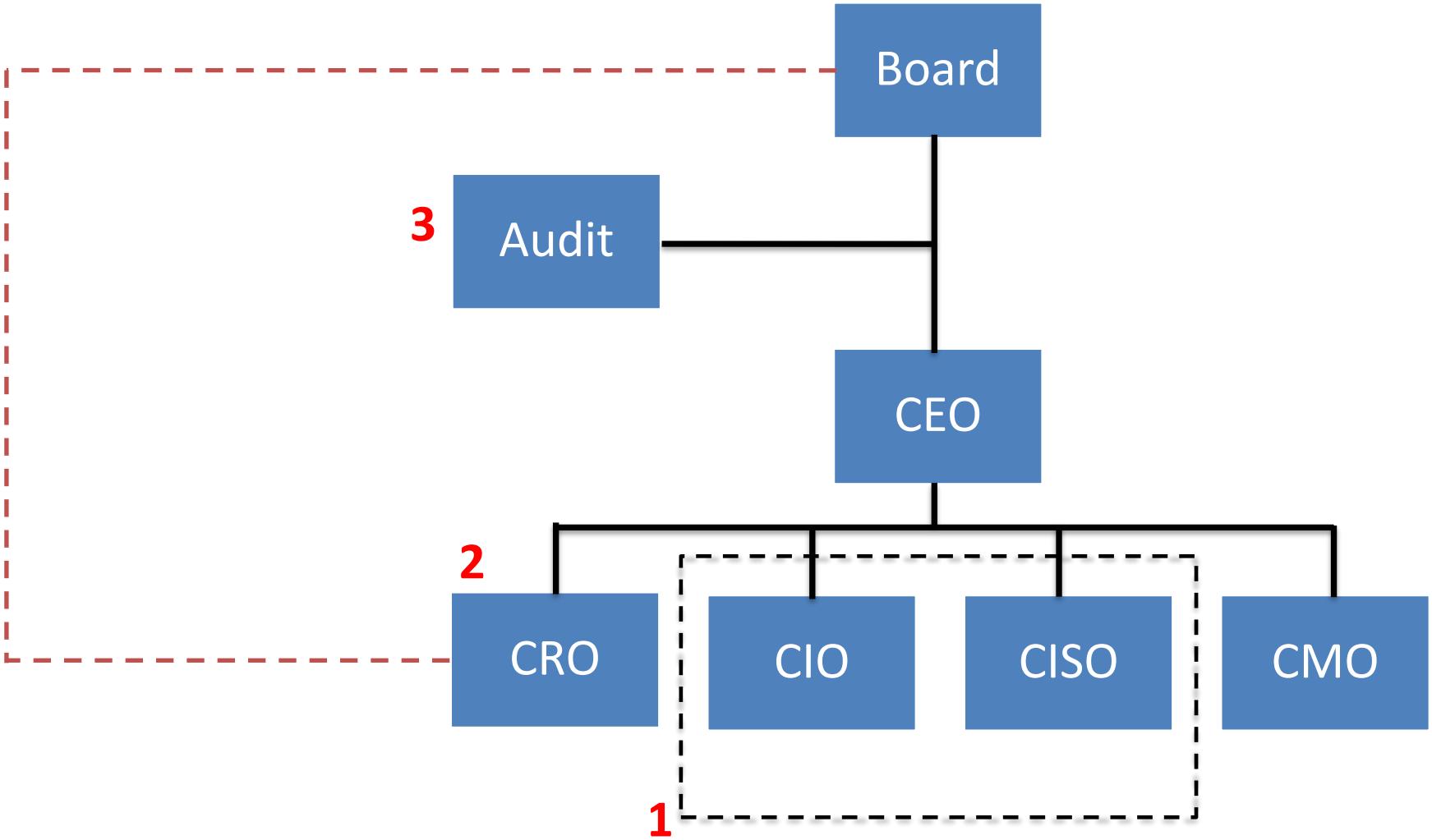
An auditor is expected to:

- Assess conformance of the risk management program against the organizationally adopted and approved standard
- Review and evaluate the design and implementation of risk management holistically
- Ensure the efficacy of the first and second lines of defense

Visualizing the Three Lines of Defense



Typical Organization



Digital Risk Management process
Triggers

TRIGGERS | IDENTIFICATION / ANALYSIS | MEASUREMENT | MANAGEMENT | MONITORING

KEY ACTIVITIES

- **Identify the triggers of Digital Risk** by monitoring **all the potential sources of risks** (regular flow of information among Local functions – e.g., Risk, Security, IT, Audit… – should be put in place)

Digital Risk Management process Identification/Analysis

TRIGGERS | **IDENTIFICATION / ANALYSIS** | MEASUREMENT | MANAGEMENT | MONITORING

KEY ACTIVITIES

- **Identify the risks** according to the **different sources**
- **Open a dedicated risk on the Local Risk Register** and **report the key features** such as: event type, risk cause, risk event, risk effect and IT assets impacted

Digital Risk Management process Measurement

TRIGGERS | IDENTIFICATION / ANALYSIS | **MEASUREMENT** | MANAGEMENT | MONITORING

KEY ACTIVITIES

- **Measure** the risks according to two different approaches:
  - ✓ **Qualitative Risk Measurement** (e.g., Heatmap)
  - ✓ **Quantitative Risk Measurement** (e.g., Cyber Risk Quantification)

Digital Risk Management process Management

TRIGGERS → IDENTIFICATION / ANALYSIS → MEASUREMENT → **MANAGEMENT** → MONITORING

KEY ACTIVITIES

- **Accept risks or evaluate and plan risk responses** (e.g., mitigation actions) on the Local Risk Register
- **Implement responses** to manage Digital risk (Risk Owners)

Digital Risk Management process Monitoring

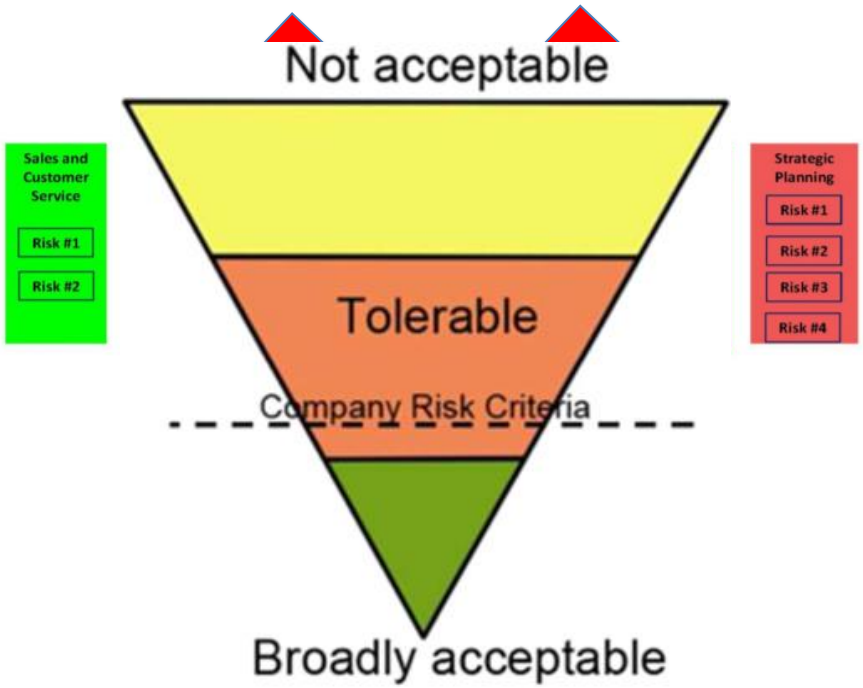
TRIGGERS → IDENTIFICATION / ANALYSIS → MEASUREMENT → MANAGEMENT → MONITORING

KEY ACTIVITIES

- **Monitor continuously** risk levels, KRIs and mitigation actions' progress
- **Prepare periodical reporting** about Digital risks for different **stakeholders** (e.g., Risk/ Executive committees, BoD, Audit, Group GRM)

Risk Management Plan

Risk Criteria



- *ERM*
- *Customized criteria*
- *Risk appetite*
- *Risk tolerance*
- *Impact areas*

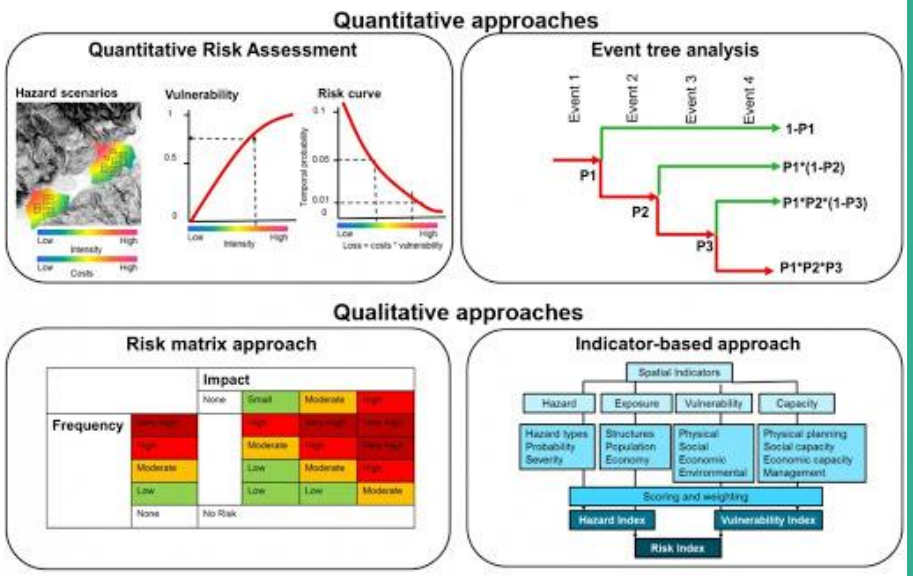
Risk Identification

- *Emergency management*
- *Evidence and historical data*
- *VA & PT*
- *BCP&DR*

Risk Assessment e Risk Analysis

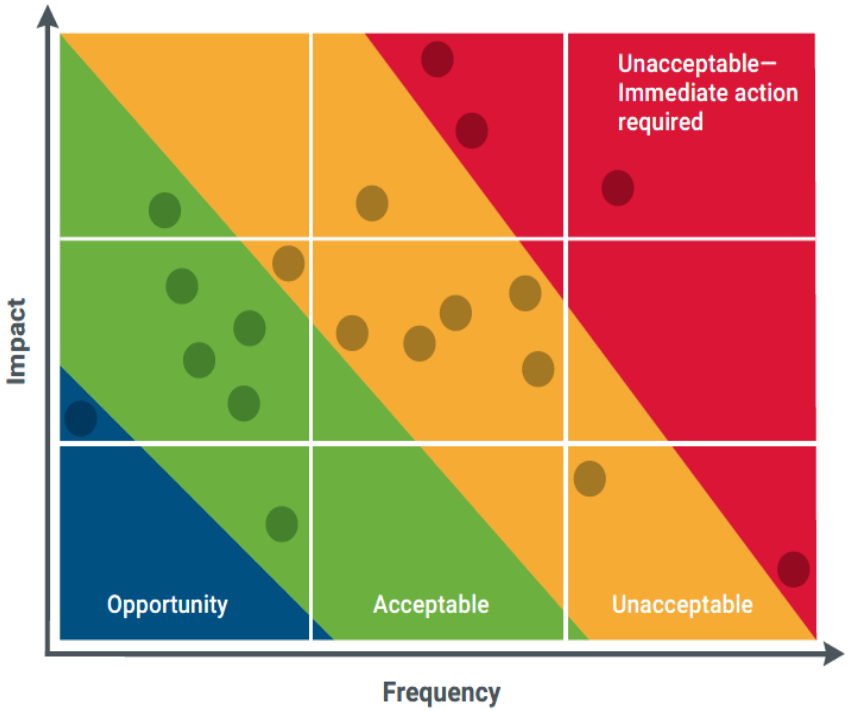
- *Analysis and evaluation*
- *Maximum foreseeable loss (MFL)*
- *Probable maximun loss (PML)*
- *Risk Register*
- *Factor Analysis of Information Risk*

Qualitative or Quantitative?



- *Business Impact*
- *Risk Mitigation*
- *Input Trigger*
- *Objective*
- *Range definition*

Risk Maps



- Risk Maps
- Impact and Frequency
- Risk acceptance
- Process maturity

Risk Register

	$1-100	$101-1000	$1001-5000	$5001-50,000	$50,001-250,000	$250,001-500,000	$500,001-1,000,000	$1,000,001-$5,000,000	Greater than 5M
Once every 10 years or less	2	2	2	2	2	2	2	2	2
Once every 5 to 10 years	12	10	8	6	1	3	1	1	1
Once every 1 to 5 years	20	18	16	2	3	1	1	1	1
Once every 1 to 4 quarters	35	25	15	1	1	1	1	1	1
Once every 1 to 3 months	60	15	10	1	1	0	0	0	0
Once every 1 to 4 weeks	100	10	8	1	0	0	0	0	0
Once every 1 to 7 days	100	11	8	1	0	0	0	0	0
1 to 10 times per day	8	1	3	0	0	0	0	0	0
More than 10 times per day	5	1	2	0	0	0	0	0	0
Total	342	93	72	14	8	7	5	5	5

	#	Name	Relevant	Abs Consequence	Abs. Likelihood	Abs Risk Level	Ctrl Consequence	Ctrl Likelihood	Ctrl Risk Level
1	1	Benefits / ROI not clearly defined	Yes	Catastrophic	Likely	Extreme	Moderate	Moderate	High
2	2	Benefits / ROI not supported with m	Yes	Major	Almost Certain	Extreme	Moderate	Unlikely	Moderate
3	3	Benefits / ROI not approved by Sr M	Yes	Major	Moderate	Extreme	Minor	Moderate	Moderate
4	4	Unclear Ownership / Responsibilitie	Yes	Catastrophic	Almost Certain	Extreme	Moderate	Unlikely	Moderate
5	5	Business Process change not clearl	No	Catastrophic	Not Set	Low	Major	Rare	High
6	6	Business Process change not appro	Yes	Moderate	Almost Certain	Extreme	Moderate	Moderate	High
7	7	Unclear Ownership / Responsibilitie	Yes	Catastrophic	Almost Certain	Extreme	Major	Moderate	Extreme
8	8	Resulting changes in Work Procedu	Yes	Moderate	Moderate	High	Moderate	Rare	Moderate
9	9	Work Procedures and Organisation	Yes	Catastrophic	Moderate	Extreme	Moderate	Moderate	High
10	10	Unclear Ownership / Responsibilitie	Yes	Catastrophic	Rare	High	Moderate	Moderate	High
11	11	Tasks assigned to Business Reps /	No	Catastrophic	Likely	Extreme	Moderate	Rare	Moderate
12	12	Arbitrary Business decisions about P	No	Major	Almost Certain	Extreme	Minor	Unlikely	Low
13	13	Supplier / Subcontracting Contracts	No	Catastrophic	Likely	Extreme	Moderate	Likely	High
14	14	Supplier / Subcontracting Contracts	No	Major	Almost Certain	Extreme	Insignificant	Almost Certain	High
15	15	Supplier / Subcontracting Contracts	No	Major	Unlikely	High	Moderate	Rare	Moderate
16	16	Parties involved in Project not all inc	No	Catastrophic	Likely	Extreme	Moderate	Rare	Moderate
17	17	Functions required in Project not all	No	Moderate	Likely	High	Minor	Likely	High
18	18	Unclear (defined / understood) Role	No	Catastrophic	Likely	Extreme	Minor	Rare	Low
19	19	Critical Positions not timely filled	No	Major	Likely	Extreme	Moderate	Likely	High
20	20	Issues / Conflicts Escalation / Reso	No	Catastrophic	Almost Certain	Extreme	Catastrophic	Rare	High
21	21	Insufficient Buy-in / Commitment of k	No	Major	Almost Certain	Extreme	Insignificant	Almost Certain	High
22	22	Project Team not physically co-locat	No	Minor	Likely	High	Minor	Unlikely	Low
23	23	Basic Equipment (office space / wo	No	Catastrophic	Moderate	Extreme	Insignificant	Moderate	Low
24	24	Standard Project Management Proc	No	Catastrophic	Moderate	Extreme	Insignificant	Unlikely	Low

- *Risk Area*
- *Risk owner*
- *Detailed informations*
- *Risk lifecycle*

NIST Cybersecurity Framework

NIST CYBERSECURITY FRAMEWORK

KEY BENEFITS OF USING NIST CSF

International Framework
Globally recognized standard that promotes protection and resilience in an adaptable way.

Common Language
Provides a common ground and platform for executives and partners to discuss cybersecurity risks.

Adaptable to many technologies, lifecycle phases, sectors and uses

Long-term Risk Management
Build for future regulations and compliance requirements.

The risk-based and **living document**

NIST CYBERSECURITY FRAMEWORK

Functions: The 'core' material of the NIST framework is split into 5 functions.

IDENTIFY
Identification, inventory, assessment, and governance of enterprise assets and related risks

PROTECT
What is important to protect, why protection is necessary, and what protections are prudent

DETECT
Deployment and management of capabilities designed to monitor for potential security incidents

RESPOND
Analysis, implementation, and maintenance of methods to address and minimise impacts of security incidents

RECOVER
Maintaining or returning the business to normal operations following security incidents

Categories: For each function there are a set of categories & sub-categories that define cybersecurity outcomes & controls.

IDENTIFY	PROTECT	DETECT	RESPOND	RECOVER
ID.AM	PR.AC	DE.AE	RS.RP	RC.RP
ID.BE	PR.AT	DE.CM	RS.CO	RC.IM
ID.GV	PR.DS	DE.DP	RS.AN	RC.CO
ID.RA	PR.IP		RS.MI	
ID.RM	PR.MA		RS.IM	
ID.SC	PR.PT			

Regulators worldwide emphasize use of NIST Cybersecurity framework as a widely recognized and respected approach for organizations to assess and improve their ability to prevent, detect and respond to cyber-attacks.

CYBER RISK MANAGEMENT BEST PRACTICES (NIST)

Core

it contains an array of activities, outcomes and references about aspects and approaches to cybersecurity

Desired cybersecurity outcomes organized in a hierarchy and aligned to more detailed guidance and controls

Implementation Tiers

they are used by an organization to clarify for itself and its partners how it views cybersecurity risk and the degree of sophistication of its management approach

A **qualitative** measure of organizational cybersecurity risk management practices

Profiles

it is a list of outcomes that an organization has chosen from the categories and subcategories, based on its needs and risk assessments

Alignment of an organization's <u>requirements</u> and <u>objectives</u>, <u>risk appetite</u> and <u>resources</u> ***using*** the desired outcomes of the Framework Core

CYBER RISK MANAGEMENT BEST PRACTICES (NIST)

Framework Core

Functions	Categories	Subcategories
Identify	Asset Management (ID.AM) Business Environment (ID.BE) Governance (ID.GV) Risk Assessment (ID.RA) Risk Management (ID.RM) Supply Chain (ID.SP)	ID.AM-1 to ID.AM-6 ID.BE-1 to ID.BE-5 ID.GV-1 to ID.GV-4 ID.RA-1 to ID.RA-6 ID.RM-1 to ID.RM-3 ID.SC-1 to ID.SC-4
Protect	Access Control (PR.AC) Awareness and Training (PR.AT) Data Security (PR.DS) Information Protection Procedures (PR.IP) Maintenance (PR.MA) Protective Technology (PR.PT)	PR.AC-1 to PR.AC-5 PR.AT-1 to PR.AT-5 PR.DS-1 to PR.DS-9 PR.IP-1 to PR.IP-11 PR.MA-1 to PR.MA-2 PR.PT-1 to PR.PT-5
Detect	Anomalies and Events (DE.AE) Security Continuous Monitoring (DE.CM) Detection Processes (DE.DP)	DE.AE-1 to DE.AE-5 DE.CM-1 to DE.CM-8 DE.DP-1 to DE.DP-5
Respond	Response Planning (RS.RP) Communications (RS.CO) Analysis (RS.AN) Mitigation (RS.MI) Improvements (RS.IM)	RS.RP-1 RS.CO-1 to RS.CO-5 RS.AN-1 to RS.AN-4 RS.MI-1 to RS.MI-3 RS.IM-1 to RS.IM-2
Recover	Recovery Planning (RC.RP) Improvements (RC.IM) Communications (RC.CO)	RC.RP-1 RC.IM-1 to RC.IM-2 RC.CO-1 to RC.CO-2

+ Informative References

Framework Tiers

Tier 4: Adaptive

- Adaptive risk management practice
- Cultural, risk-informed program
- Actively shares information

Tier 3: Repeatable

- Formalized risk management
- Organization-wide program
- Receives external partner info

Tier 2: Risk Informed

- Some risk management practices
- Increased awareness, no program
- Informal external participation

Tier 1: Partial

- Ad hoc risk management
- Limited cybersecurity risk awareness
- Low external participation

Strong

Weak

Framework Profile

Target Profile

Desired state of alignment between core elements and organizational requirements, risk tolerance, & resources

Where do I aspire to be relative to the Framework?

Improvement Opportunity

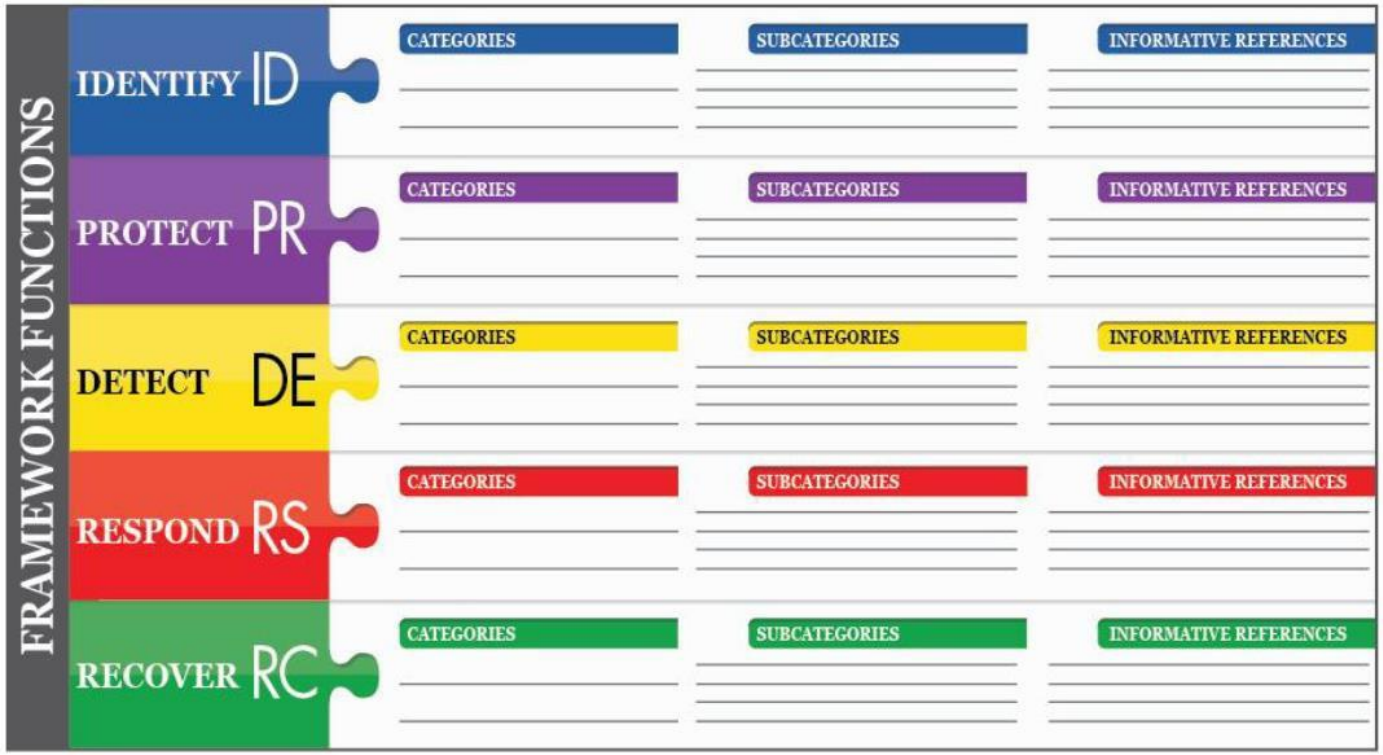
Current Profile

Current state of alignment between core elements and organizational requirements, risk tolerance, & resources

Where am I today relative to the Framework?

Framework Core

The ***Framework Core*** provides a set of activities to achieve specific cybersecurity *outcomes*, and references examples of guidance to achieve those outcomes.



The **Core** comprises four elements: Functions, Categories, Subcategories, and Informative References.

Framework Core: Functions

Function	
Identify	The **Identify function** helps develop an organizational understanding of information security risk management for systems, people, resources, data, and capabilities.
Protect	The **Protect function** supports the ability to limit or contain the impact of potential cyber security and outlines safeguards for the delivery of critical services.
Detect	The **Detect function** defines dedicated activities to identify the occurrence of a cyber security event in a timely manner.
Respond	The **Respond function** includes appropriate activities to act on a cybersecurity incident detected and minimize the impact.
Recover	The **Recover function** identifies appropriate activities to maintain resilience plans and restore damaged services during cybersecurity incidents.

Framework Core: Categories

Function	Category	ID
Identify	Asset Management	ID.AM
	Business Environment	ID.BE
	Governance	ID.GV
	Risk Assessment	ID.RA
	Risk Management Strategy	ID.RM
	Supply Chain Risk Management	ID.SC
Protect	Identity Management and Access Control	PR.AC
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Information Protection Processes & Procedures	PR.IP
	Maintenance	PR.MA
	Protective Technology	PR.PT
Detect	Anomalies and Events	DE.AE
	Security Continuous Monitoring	DE.CM
	Detection Processes	DE.DP
Respond	Response Planning	RS.RP
	Communications	RS.CO
	Analysis	RS.AN
	Mitigation	RS.MI
	Improvements	RS.IM
Recover	Recovery Planning	RC.RP
	Improvements	RC.IM
	Communications	RC.CO

The **Categories** were designed to cover the breadth of cybersecurity objectives for an organization, while not being overly detailed.
It covers topics across cyber, physical, and personnel, with a focus on business outcomes.

NIST
National Institute of Standards and Technology
U.S. Department of Commerce

Framework Core: Subcategories

Function	Category	ID
Identify	Asset Management	ID.AM
	Business Environment	ID.BE
	Governance	ID.GV
	Risk Assessment	ID.RA
	Risk Management Strategy	ID.RM
	Supply Chain Risk Management	ID.SC
Protect	Identity Management and Access Control	PR.AC
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Information Protection Processes & Procedures	PR.IP
	Maintenance	PR.MA
	Protective Technology	PR.PT
Detect	Anomalies and Events	DE.AE
	Security Continuous Monitoring	DE.CM
	Detection Processes	DE.DP
Respond	Response Planning	RS.RP
	Communications	RS.CO
	Analysis	RS.AN
	Mitigation	RS.MI
	Improvements	RS.IM
Recover	Recovery Planning	RC.RP
	Improvements	RC.IM
	Communications	RC.CO

5 functions 23 categories

108 subcategories

Subcategory	Informative References
PR.DS-1: Data-at-rest is protected	· **CIS CSC** 13, 14 · **COBIT 5** APO01.06, BAI02.01, BAI06.01, DSS04.07, DSS05.03, DSS06.06 · **ISA 62443-3-3:2013** SR 3.4, SR 4.1 · **ISO/IEC 27001:2013** A.8.2.3 · **NIST SP 800-53 Rev. 4** MP-8, SC-12, SC-28
PR.DS-2: Data-in-transit is protected	· **CIS CSC** 13, 14 · **COBIT 5** APO01.06, DSS05.02, DSS06.06 · **ISA 62443-3-3:2013** SR 3.1, SR 3.8, SR 4.1, SR 4.2 · **ISO/IEC 27001:2013** A.8.2.3, A.13.1.1, A.13.2.1, A.13.2.3, A.14.1.2, A.14.1.3 · **NIST SP 800-53 Rev. 4** SC-8, SC-11, SC-12
PR.DS-3: Assets are formally managed throughout removal, transfers, and disposition	· **CIS CSC** 1 · **COBIT 5** BAI09.03 · **ISA 62443-2-1:2009** 4.3.3.3.9, 4.3.4.4.1 · **ISA 62443-3-3:2013** SR 4.2 · **ISO/IEC 27001:2013** A.8.2.3, A.8.3.1, A.8.3.2, A.8.3.3, A.11.2.5, A.11.2.7 · **NIST SP 800-53 Rev. 4** CM-8, MP-6, PE-16
PR.DS-4: Adequate capacity to ensure availability is maintained	· **CIS CSC** 1, 2, 13 · **COBIT 5** APO13.01, BAI04.04 · **ISA 62443-3-3:2013** SR 7.1, SR 7.2 · **ISO/IEC 27001:2013** A.12.1.3, A.17.2.1 · **NIST SP 800-53 Rev. 4** AU-4, CP-2, SC-5
PR.DS-5: Protections against data leaks are implemented	· **CIS CSC** 13 · **COBIT 5** APO01.06, DSS05.04, DSS05.07, DSS06.02 · **ISA 62443-3-3:2013** SR 5.2 · **ISO/IEC 27001:2013** A.6.1.2, A.7.1.1, A.7.1.2, A.7.3.1, A.8.2.2, A.8.2.3, A.9.1.1, A.9.1.2, A.9.2.3, A.9.4.1, A.9.4.4, A.9.4.5, A.10.1.1, A.11.1.4, A.11.1.5, A.11.2.1, A.13.1.1, A.13.1.3, A.13.2.1, A.13.2.3, A.13.2.4, A.14.1.2, A.14.1.3 · **NIST SP 800-53 Rev. 4** AC-4, AC-5, AC-6, PE-19, PS-3, PS-6, SC-7, SC-8, SC-13, SC-31, SI-4
PR.DS-6: Integrity checking mechanisms are used to verify software, firmware, and information integrity	· **CIS CSC** 2, 3 · **COBIT 5** APO01.06, BAI06.01, DSS06.02 · **ISA 62443-3-3:2013** SR 3.1, SR 3.3, SR 3.4, SR 3.8 · **ISO/IEC 27001:2013** A.12.2.1, A.12.5.1, A.14.1.2, A.14.1.3, A.14.2.4 · **NIST SP 800-53 Rev. 4** SC-16, SI-7
PR.DS-7: The development and testing environment(s) are separate from the production environment	· **CIS CSC** 18, 20 · **COBIT 5** BAI03.08, BAI07.04 · **ISO/IEC 27001:2013** A.12.1.4 · **NIST SP 800-53 Rev. 4** CM-2
PR.DS-8: Integrity checking mechanisms are used to verify hardware integrity	· **COBIT 5** BAI03.05 · **ISA 62443-2-1:2009** 4.3.4.4.4 · **ISO/IEC 27001:2013** A.11.2.4 · **NIST SP 800-53 Rev. 4** SA-10, SI-7

Subcategories are the deepest level of abstraction in the Core. There are 108 Subcategories, which are outcome-driven statements that provide considerations for creating or improving a cybersecurity program. Because the Framework is outcome driven and does not mandate how an organization must achieve those outcomes, it enables risk-based implementations that are customized to the organization's needs.

NIST
National Institute of Standards and Technology
U.S. Department of Commerce

Risk Identification over emerging technologies

Impact of Technology trend on Cyber Risk

IoT

IoT devices are becoming increasingly common in homes and businesses, creating new opportunities for cyber attackers to exploit vulnerabilities in these devices to gain access to sensitive data and networks

AI

AI is being used more frequently to automate and optimize business processes, but this technology also introduces new risks, such as the potential for malicious actors to use AI to conduct more sophisticated attacks

CLOUD COMPUTING

Cloud computing has transformed the way businesses store and process data, but it also introduces new risks related to data privacy, data security, and compliance

5G CONNECTIVITY

The increased bandwidth and faster speeds offered by 5G connectivity enable more data to be transferred at faster speeds, but it also introduces new risks related to data privacy, data security, and compliance

QUANTUM COMPUTING

Quantum computing has the potential to significantly increase processing power, but it also introduces new risks related to data security, as current encryption methods may not be secure against quantum attacks

As technology continues to evolve, it is essential that organizations stay **informed about emerging trends** and the **associated cyber risks**. Effective cyber risk management requires **ongoing monitoring**, **evaluation**, and **adaptation to new threats and vulnerabilities**. By staying up-to-date on emerging technology trends, organizations can **better anticipate and mitigate potential cyber risks**

Internet of Things (IoT) and cyber risk

WHAT IS

The **Internet of Things** (IoT) refers to the **growing network of internet-connected devices**, from **smart home devices** like thermostats and security cameras to **industrial control systems** in factories and critical infrastructure. While the IoT **provides many benefits**, it **also introduces new** and **significant cyber risks**

Lack of Security Standards

IoT devices often lack robust security standards, making them vulnerable to attacks that can compromise sensitive data or take over connected systems

Complexity of IoT Networks

IoT networks are complex and often involve a large number of devices, making it challenging to monitor and secure them effectively

Data Privacy Risks

IoT devices collect a large amount of data, some of which may be sensitive. Unauthorized access to this data can result in significant privacy violations

Botnet Attacks

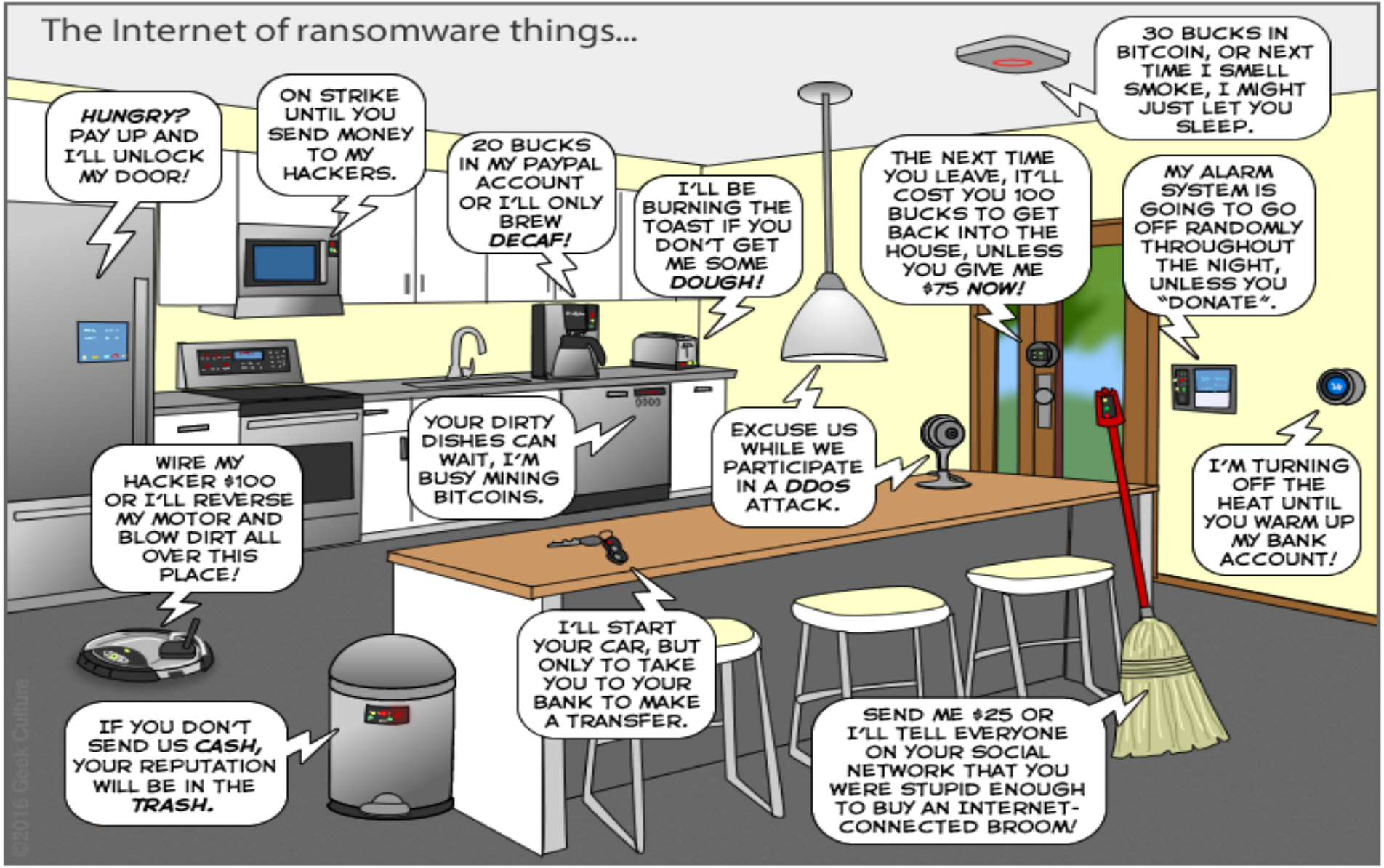
IoT devices can be compromised and used to form botnets, which can be used to launch large-scale distributed denial of service (DDoS) attacks that can disrupt networks and cause significant damage

Physical Risks

In some cases, the compromise of IoT devices can have physical consequences, such as the manipulation of sensors or the control of critical infrastructure systems

How mitigate the risk

Organizations should implement **security controls** such as network segmentation, access controls, and monitoring solutions, perform **regular vulnerability assessments** and **patch management** to ensure that IoT devices are up-to-date and secure and, finally, ensure that **all connected devices are managed** as part of a comprehensive cybersecurity strategy and **subject to appropriate security standards and policies**


The Internet of ransomware things...
HUNGRY? PAY UP AND I'LL UNLOCK MY DOOR!
ON STRIKE UNTIL YOU SEND MONEY TO MY HACKERS.
20 BUCKS IN MY PAYPAL ACCOUNT OR I'LL ONLY BREW DECAF!
I'LL BE BURNING THE TOAST IF YOU DON'T GET ME SOME DOUGH!
THE NEXT TIME YOU LEAVE, IT'LL COST YOU 100 BUCKS TO GET BACK INTO THE HOUSE, UNLESS YOU GIVE ME $75 NOW!
30 BUCKS IN BITCOIN, OR NEXT TIME I SMELL SMOKE, I MIGHT JUST LET YOU SLEEP.
MY ALARM SYSTEM IS GOING TO GO OFF RANDOMLY THROUGHOUT THE NIGHT, UNLESS YOU "DONATE".
YOUR DIRTY DISHES CAN WAIT, I'M BUSY MINING BITCOINS.
EXCUSE US WHILE WE PARTICIPATE IN A DDOS ATTACK.
I'M TURNING OFF THE HEAT UNTIL YOU WARM UP MY BANK ACCOUNT!
WIRE MY HACKER $100 OR I'LL REVERSE MY MOTOR AND BLOW DIRT ALL OVER THIS PLACE!
I'LL START YOUR CAR, BUT ONLY TO TAKE YOU TO YOUR BANK TO MAKE A TRANSFER.
IF YOU DON'T SEND US CASH, YOUR REPUTATION WILL BE IN THE TRASH.
SEND ME $25 OR I'LL TELL EVERYONE ON YOUR SOCIAL NETWORK THAT YOU WERE STUPID ENOUGH TO BUY AN INTERNET-CONNECTED BROOM!
©2016 Geek Culture

Artificial Intelligence (AI) and cyber risk

WHAT IS

Artificial intelligence (AI) is a **rapidly growing field** that is revolutionizing many industries, including cybersecurity. While AI can **provide significant benefits** for **detecting** and **responding to cyber threats**, it can **also introduce new cyber risks**

Adversarial Attacks

AI systems can be trained using adversarial attacks, which are specifically designed to exploit vulnerabilities in machine learning algorithms. These attacks can result in false positives or false negatives, leading to incorrect decisions and actions

Bias and Discrimination

AI systems can introduce bias and discrimination, particularly if they are trained on biased data sets. This can result in unfair or unethical decision-making and may lead to legal and reputational risks

Lack of Transparency

AI systems can be complex and difficult to understand, making it challenging to identify and address potential security issues

Data Privacy Risks

AI systems often require access to large amounts of data, some of which may be sensitive. Unauthorized access to this data can result in significant privacy violations

Misuse

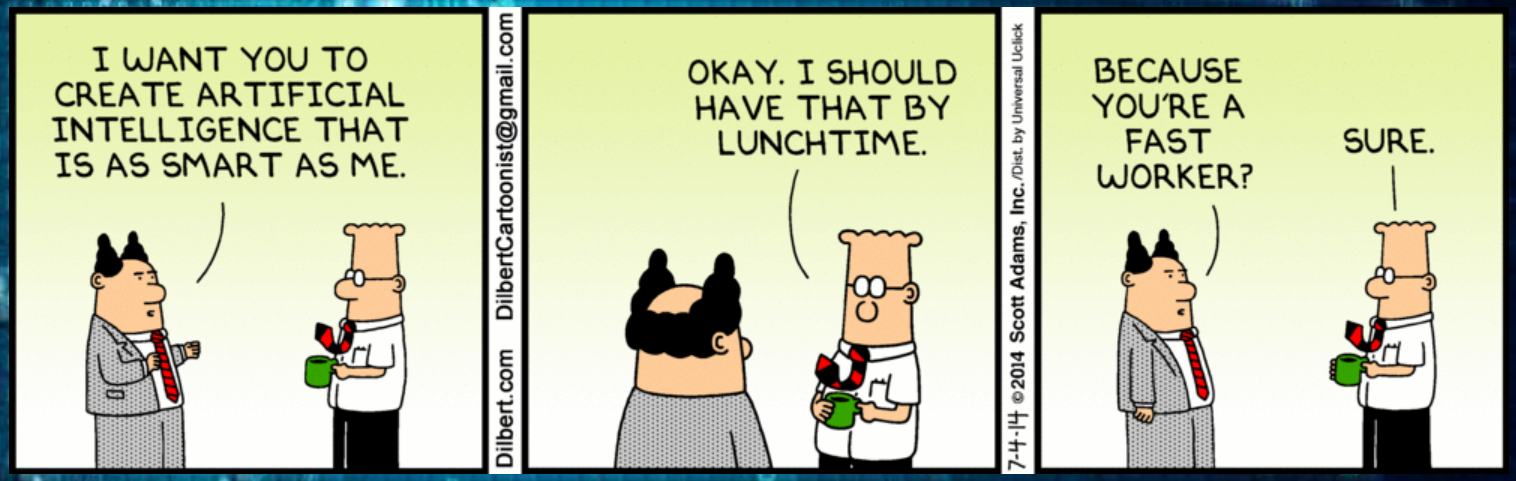
AI systems can be misused, for example, to conduct social engineering attacks or to create fake news

How mitigate the risk

Organizations should **implement appropriate security controls**, such as access controls, encryption, and monitoring solutions, perform **regular vulnerability assessments** and patch management to ensure that AI systems are up-to-date and secure. Finally, organizations should ensure that all AI systems are **subject to appropriate security standards** and **policies** and are **transparent** and **explainable**

44

Artificial Intelligence



Cloud computing and cyber risk

WHAT IS

Cloud computing is a **popular way for organizations to store, process**, and **manage data** and **applications**. While the cloud computing **provides many benefits**, it **also introduces new** and **significant cyber risks**

Data Breaches

Cloud providers store a large amount of sensitive data, making them an attractive target for cyber attackers. A data breach can result in the loss of confidential data, intellectual property, and other sensitive information

Insider Threats

Cloud providers have a large number of employees with access to sensitive data, making them vulnerable to insider threats. Employees can intentionally or unintentionally cause data breaches, or maliciously use data for personal gain

Compliance Risks

Storing data in the cloud can result in compliance risks, particularly if data is stored in a location that is subject to different regulations and laws than the organization's home country

Supply Chain Risks

The use of cloud services may introduce supply chain risks if the cloud provider relies on third-party vendors for critical services

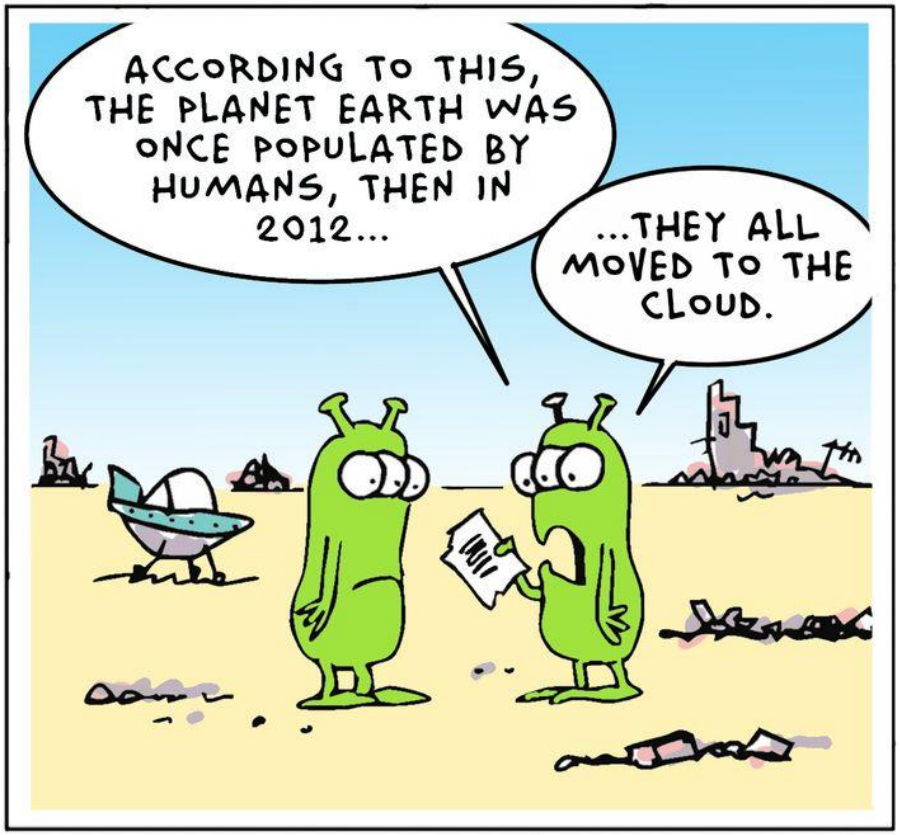
Data Loss

While cloud providers often have robust backup and disaster recovery capabilities, data loss can still occur due to hardware failures, human error, or other factors

How mitigate the risk

Organizations should **perform due diligence when selecting cloud providers**, implement appropriate security controls, and monitor the cloud environment for unusual activity. It is also important to ensure that all **data stored** in the cloud is subject to appropriate **security standards** and **access controls**. Finally, organizations should have a **clear understanding of their regulatory obligations** and the potential implications of storing data in the cloud

NETWORK'S DOWN AGAIN...
CLOUD COMPUTING MY ASS.
Mashable Comics
Written by @Matt_Silverman
Illustrated by Kiersten Essenpreis


ACCORDING TO THIS, THE PLANET EARTH WAS ONCE POPULATED BY HUMANS, THEN IN 2012...
...THEY ALL MOVED TO THE CLOUD.

Blockchain and cyber risks

WHAT IS

Blockchain is a **distributed ledger technology** that is **used to store** and **share data in a secure and transparent manner**. While blockchain is **often touted as a secure** and **trustworthy technology, it also introduces new cyber risks**

Smart Contract Vulnerabilities

Smart contracts are self-executing contracts that are stored on the blockchain. Smart contracts can be vulnerable to code vulnerabilities, which can result in security breaches and loss of funds

51% Attack

A 51% attack is a type of attack where an attacker gains control of the majority of the computing power on a blockchain network. This can enable the attacker to manipulate the blockchain and commit fraud

Privacy Risks

While blockchain is often touted as a privacy-enhancing technology, it can also introduce new privacy risks. Blockchain transactions are publicly visible, which can result in the exposure of sensitive information

Insider Threats

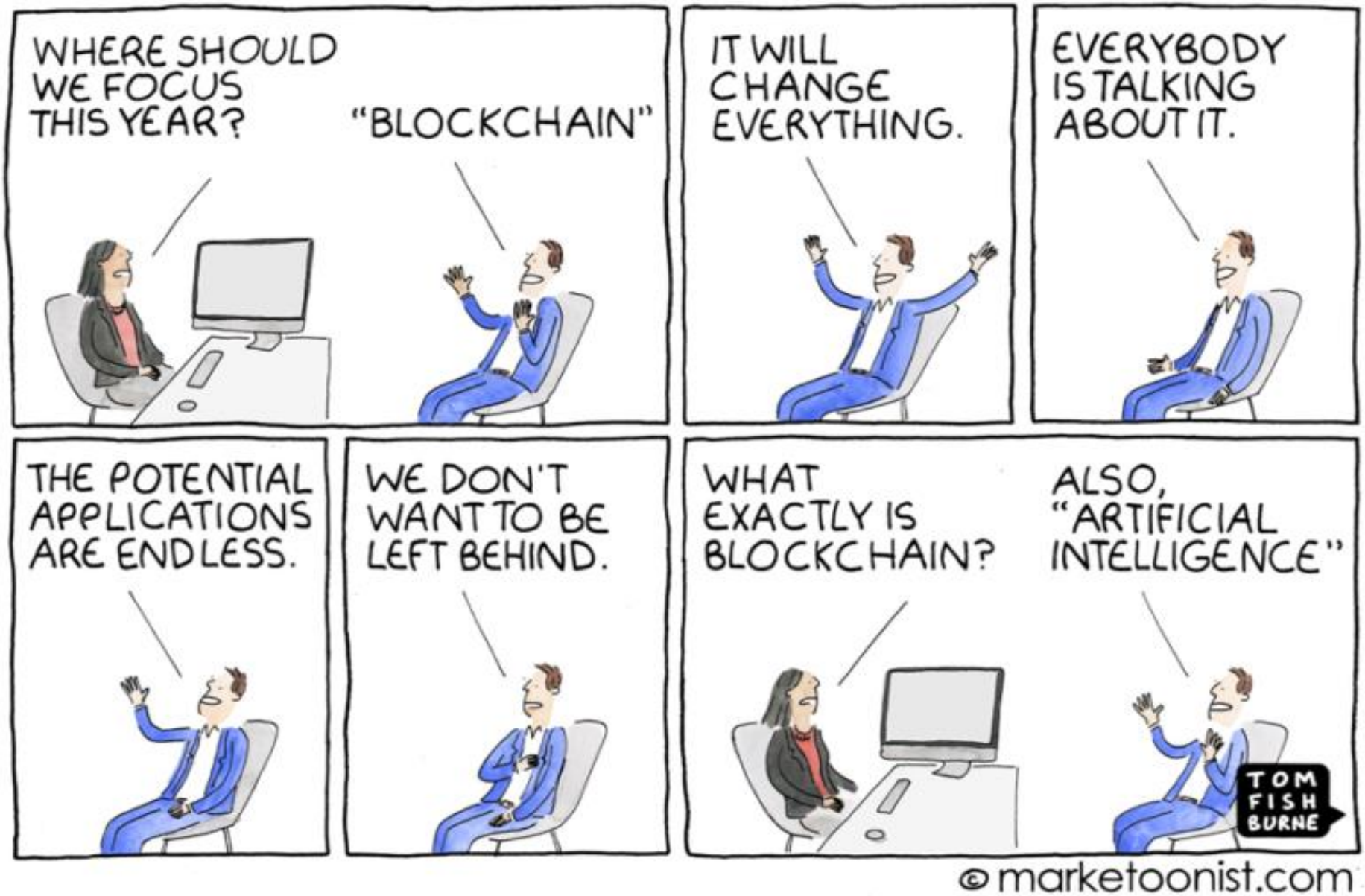
Insiders with access to blockchain networks can introduce vulnerabilities or commit fraud, particularly in the case of private blockchains

Smart Contract Risks

Smart contracts can introduce new risks, particularly if they are not designed and implemented correctly. For example, smart contracts can be vulnerable to coding errors, which can result in security breaches and loss of funds

How mitigate the risk

Organizations should **implement appropriate security controls**, including access controls, monitoring, and threat intelligence. It is also essential to perform **regular vulnerability assessments** and **penetration testing** to ensure that blockchain networks are secure. Finally, organizations should ensure that **smart contracts are designe**d and **implemented correctly** and subject to appropriate **security standards and policies**


WHERE SHOULD WE FOCUS THIS YEAR?
"BLOCKCHAIN"
IT WILL CHANGE EVERYTHING.
EVERYBODY IS TALKING ABOUT IT.
THE POTENTIAL APPLICATIONS ARE ENDLESS.
WE DON'T WANT TO BE LEFT BEHIND.
WHAT EXACTLY IS BLOCKCHAIN?
ALSO, "ARTIFICIAL INTELLIGENCE"
TOM FISH BURNE
© marketoonist.com

“our” Risk Management Plan

"How to start"

- We have a support excel to perform our risk management plan (SecRAM-example.xls)
- This file will be used for several exercise in "Qualitative" part of this course
- It's not mandatory to execute all the exercise but it's very helpful for final report

Step 1: Identify Assets

- **Identify Primary Assets *(what I want to protect)***

1.1 Primary Assets Identification

Step 1: Impact Assessment			
1.1. Primary Asset (PA) Identification			
Primary Asset ID	***Primary Asset Name***	***Type (information/service)***	***Justification***
PA1	*Ability to jump to light speed*	service	This is the core feature of the space ship
PA2	*Death Star plans*	information	The plans contain information about the Death Star design and the construction milestones

Step 1: Identify Assets

- Identify Primary Assets *(what I want to protect)*
- **Perform Impact Assessment on primary assets *(establish their relevance for business)***

1.2 Impact Assessment on Primary Assets

Step 1: Impact Assessment										
1.2 Impact Assessment on Primary Assets										
Primary Asset Name	***Potential Compromise of C, I or A:***	***Impact (see Table in the Methodology)***								
		Personnel	**Capacity**	**Performance**	**Economic**	**Branding**	**Regulatory**	**Environment**	**Overall Impact (1.2)**	**Justification**
Ability to jump to light speed	C	1	1	1	1	1	1	1	1	No problem if people know about the ability of a ship to fly fast
	I	4	2	4	4	3	2	1	4	In case of an unauthorised modification, the ability to do hyperspace jumps is available but somehow damaged (e.g., others can track the ship position).
	A	4	3	4	2	3	1	1	4	If not available, the Empire might actually chase and catch the ship
Death Star plans	C	4	3	3	3	2	1	1	4	If it becomes known that ship has Death Star plans, then the Empire and other bad people start chasing the ship
	I	3	2	2	3	2	1	3	3	If damaged, it becomes quite difficult for the Rebellion to plan the attack on the Death Star and save many people lives
	A	4	2	4	4	2	1	3	4	If not available, the plan for an attack on the Death Star becomes impossible, which might lead to death of many people.
0	C									
	I									
	A									
0	C									
	I									
	A									
0	C									
	I									
	A									

Step 1: Identify Assets

- Identify Primary Assets *(what I want to protect)*
- Perform Impact Assessment on primary assets *(establish their relevance for business)*
- ***Identify Supporting Assets and link with primary assets***

1.3 Supporting Asset Identification & Valuation

Step 1: Supporting Asset Identification & Valuation

1.3 Linkage with Primary Assets					
Primary Asset / Supporting Asset	Ability to jump to light speed	Death Star plans	0	0	0
Reactor Engine	x	x			
R2D2		x			

Step 1: Common mistakes

- **Lack of primary assets (analyze the case study)**
- **Lack of supporting assets (remember the SECRam seven domains)**
- **Under(over)-estimation of impact**

Step 2: Threat Evaluation

- **Identify vulnerabilities & Threat Scenarios *(what's threating my business)***

2.1 Vulnerabilities & Threat Scenarios Evaluation

Step 2: Threat Evaluation

Step 2.1: Vulnerabilities & Threat Scenarios Evaluation

Supporting Asset (same as specified in step 2)	*Threat*	*Vulnerability*	*Primary Assets (specify a separate column for each primary asset specified in step 1.1)*															*Inherited impact*	*Reviewed Impact*	Justification for attenuating circumstances
			Ability to jump to light speed			Death Star plans			0			0			...					
			C	I	A	C	I	A	C	I	A	C	I	A	C	I	A	MAX	<=	
(Same values as specified in column 1.2 Overall Impact) Impact ->			1	4	4	4	3	4	0	0	0	0	0	0						
Reactor Engine	Threat A		Y		Y													4	4	
	Threat B					Y												4	4	
	Threat C																	1	1	
R2D2	Threat X																	1	1	
	Threat Y																	1	1	
	Threat Z																	1	1	
0	Threat X																	1	1	
	Threat Y																	1	1	
	Threat Z																	1	1	
0	Threat X																	1	1	
	Threat Y																	1	1	
	Threat Z																	1	1	
0	Threat X																	1	1	
	Threat Y																	1	1	
	Threat Z																	1	1	

Step 2: Threat Evaluation

- Identify vulnerabilities & Threat Scenarios *(what's threating my business)*
- **Estimate likelihood *(level of certain)***

2.2 Likelihood Assessment on Supporting Assets

Step 2: Threat Evaluation

2.2 Likelihood Assessmenton Supporting Assets

Supporting Asset (same as specified in step 2)	*Threat*	*Vulnerability*	*Likelihood Areas (see Table in the Methodology)*								
			Skills	Means	Opportunity	Profit	Attention	Impunity	Detection	Overall Likelihood (2.2)	Justification
Reactor Engine	*Threat A*									0	
	Threat B									0	
	Threat C									0	
R2D2	*Threat X*									0	
	Threat Y									0	
	Threat Z									0	
0	*Threat X*									0	
	Threat Y									0	
	Threat Z									0	
0	*Threat X*									0	
	Threat Y									0	
	Threat Z									0	
0	*Threat X*									0	
	Threat Y									0	
	Threat Z									0	

Step 2: Common mistakes

- Lack of obvious threat (e.g. power failure)
- Under(over)-estimation of likelihood
- Mistakes in Step 1

Step 3: Risk Evaluation

- **Define your Risk Table**

3.1 Risk Table

	Reviewed Impact				
Likelihood	1. No impact, NA	2. Minor	3. Severe	4. Critical	5. Catastrophic
5. Certain	Low	High	High	High	High
4. Very likely	Low	Medium	High	High	High
3. Likely	Low	Low	Medium	High	High
2. Unlikely	Low	Low	Low	Medium	High
1. Very Unlikely	Low	Low	Low	Medium	Medium

	Reviewed Impact				
Likelihood	1. No impact, NA	2. Minor	3. Severe	4. Critical	5. Catastrophic
5. Certain	Low	Medium	High	High	High
4. Very likely	Low	Medium	Medium	High	High
3. Likely	Low	Low	Medium	High	High
2. Unlikely	Low	Low	Low	Medium	Medium
1. Very Unlikely	Low	Low	Low	Low	Medium

Step 3: Risk Evaluation

- Define your Risk Table
- **Perform your risk evaluation (*based on Impact and Likelihood*)**

3.2 Risk Evaluation

Step 3: Risk Evaluation					
Step 3.2: Risk Evaluation					
Supporting Assets(same as specified in step 2.1)	***Threats (same as specified in step 2.1)***	***Vulnerability (same as specified in step 2.1)***	***Reviewed Impact (from step 2.1)***	***Likelihood (from step 2.2)***	***Risk level (from Table 3.1)***
Reactor Engine	Threat A		4		
	Threat B		4		
	Threat C		1		
R2D2	Threat X		1		
	Threat Y		1		
...	...		1		

Step 3: Common mistakes

- **It would be the first time**

Step 4: Risk Treatment

- **Identify the best risk Treatment and calculate Residual Risk for Supporting Assets**

Step 4: Risk Treatment

Step 4.1: Risk Treatment and Calculation of Residual Risk for Supporting Assets

Supporting Assets (same as specified in step 2.1)	*Threats (same as specified in step 3.1)*	*Vulnerability (same as specified in step 3.1)*	*Pre- Controls*	*Post-Controls*	*Reviewed Impact (from step 3.1)*	*Likelihood (from step 3.2)*	*Residual Impact*	*Residual Likelihood*	*Residual Risk level (from Table 3.1)*
Reactor Engine	Threat A		Pre-Control A1	Post-Control A1					
			Pre-Control A2						
	Threat B		Pre-Control B1	Post-Control B1					
	Threat C		Pre-Control C1						
R2D2	Threat X		Pre-Control X1	Post-Control X1					
				Post-Control X2					
			Pre-Control X2						
	Threat Y			Post-Control Y1					
	Threat Z		Pre-Control Z1						
			Pre-Control Z2						
...	...		...	...					

Step 4: Common mistakes

- **Lack of obvious Controls (e.g. procedure)**
- **Under(over)-estimation of controls efficiency**
- **Mistakes in Step 1**

Step 5: Residual Risk

- **Identify the Residual Risk for Primary Assets**

Step 5: Residual Risk

5.1 Back Linkage of 4.1 Residual Risk for Supporting Assets to Primary

Primary Asset / Supporting Asset	Ability to jump to light speed	Death Star plans	0	0	0
Supporting Asset 1 Name					
Supporting Asset 2 Name					
Supporting Asset 3 Name					
Supporting Asset 4 Name					
Supporting Asset 5 Name					
Supporting Asset 6 Name					
Supporting Asset 7 Name					
Supporting Asset 8 Name					
Supporting Asset 9 Name					
Supporting Asset 10 Name					
Residual Risk for Primary Assets	***0***	***0***	***0***	***0***	***0***

Step 5: Common mistakes

- **Just consider excel formulas**

Vrae?
Afrikaans

Questions?
English

¿Preguntas?
Spanish

Cwestiynau?
Welsh

Imibuzo?
Zulu

Quaestiones?
Latin

Ερωτήσεις;
Greek

Вопросы?
Russian

Fragen?
German

問題呢?
Chinese

Domande?
Italian

أسئلة؟
Arabic

質問？
Japanese

שאלות?
Jewish

tupoQghachmey?
Klingon

Questions?
French